

Zadanie domowe | Lekcja 9 | 27.08.2026

Tytuł: Podejrzana aktywność sieciowa hosta 10.0.0.24

Zakres materiału:

- nazwa i SHA-256 pliku:
- źródło i punkt przechwycenia:
- przedział czasu i strefa:
- znane ograniczenia:

Podsumowanie:

- 2–3 zdania opisujące najważniejszy wynik i jego znaczenie.

Chronologia:

- czas — źródło:port -> cel:port — obserwacja
- czas — źródło:port -> cel:port — obserwacja

Dowody:

- numer ramki lub strumienia:
- zastosowany filtr:
- zaobserwowane pola i statystyki:

Ocena:

- hipoteza:
- alternatywne wyjaśnienie:
- poziom pewności: niski / średni / wysoki

Rekomendowane działania:

- korelacja z logami lub EDR,
- identyfikacja właściciela i procesu,
- ewentualna izolacja zgodnie z procedurą IR.

Scenariusz 3

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	183.79.215.137	192.168.10.9	TCP	66	443 → 2858 [ACK] Seq=1 Ack=1 Win=33 Len=0 SLE=0 SRE=1
2	0.092121	192.168.10.51	162.213.33.50	TCP	74	49769 → 443 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PER
3	0.178618	192.168.10.9	23.50.75.27	TCP	60	2869 → 80 [ACK] Seq=1 Ack=1 Win=256 Len=1
4	0.178621	192.168.10.9	23.50.75.27	TCP	60	2870 → 80 [ACK] Seq=1 Ack=1 Win=256 Len=1
5	0.187451	162.213.33.50	192.168.10.51	TCP	74	443 → 49769 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=14
6	0.187482	192.168.10.51	162.213.33.50	TCP	66	49769 → 443 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=12992
8	0.201809	23.50.75.27	192.168.10.9	TCP	66	80 → 2869 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
9	0.201812	23.50.75.27	192.168.10.9	TCP	66	80 → 2870 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
11	0.273976	93.184.215.129	192.168.10.9	TCP	66	443 → 2819 [ACK] Seq=1 Ack=2 Win=340 Len=0 SLE=1 SRE=2
12	0.283659	162.213.33.50	192.168.10.51	TCP	66	443 → 49769 [ACK] Seq=1 Ack=149 Win=30080 Len=0 TSval=951
15	0.492508	192.168.10.5	72.21.91.29	TCP	60	50992 → 80 [ACK] Seq=1 Ack=1 Win=253 Len=1
17	0.514063	93.184.215.129	192.168.10.9	TCP	66	443 → 2821 [ACK] Seq=1 Ack=2 Win=336 Len=0 SLE=1 SRE=2
18	0.516242	72.21.91.29	192.168.10.5	TCP	66	80 → 50992 [ACK] Seq=1 Ack=2 Win=288 Len=0 SLE=1 SRE=2

> Frame 1: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528	0000	b8 ac 6f 1d 1f 6c 00 c1 b1 14 eb 31 08 00 45 00	..o..1... ..1
> Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_1d:1	0010	00 34 17 96 40 00 2f 06 da a3 b7 4f d7 89 c0 a8	.4...@./... ..0
> Internet Protocol Version 4, Src: 183.79.215.137, Dst: 192.168.10.9	0020	0a 09 01 bb 0b 2a 2c 02 a0 8a 41 10 10 5b 80 10	*,... ..A.
> Transmission Control Protocol, Src Port: 443, Dst Port: 2858, Seq: 1	0030	00 21 52 5f 00 00 01 01 05 0a 41 10 10 5a 41 10	..!R..... ..A.
	0040	10 5b	..[

Wireshark → Statistics → Capture File Properties → Time

Wireshark · Szczegóły pliku przechwytywania · scenario3.pcapng	
Szczegóły	
Plik	
Nazwa:	C:\Users\tymin\AppData\Local\Temp\5d5fc393-580d-4d59-97f3-b0905372a48f_scenario3.pcapng.zip.48f\scenario3.pcapng
Rozmiar:	40 MB
Hash (SHA256):	af94cd4ec607d4e8aba9968c7fece1b5bf1742c067551e2925849b1526eac638
Hash (SHA1):	035f505d62974847c16584e3bb6f0e2c61a992bb
Format:	Wireshark/... - pcapng
Enkapsulacja:	Ethernet
Czas	
Pierwszy pakiet:	2017-07-06 15:39:00
Ostatni pakiet:	2017-07-06 15:44:59
Minęło:	00:05:59

ip.addr==172.16.0.1 && ip.addr==192.168.10.50 && http

No.	Time	Source	Destination	Protocol	Length	Info
9506	67.249376	172.16.0.1	192.168.10.50	HTTP	513	GET /dv/vulnerabilities/sqli/?id=1%27&Submit=Submit HTTP/1.1
9508	67.253046	192.168.10.50	172.16.0.1	HTTP	596	HTTP/1.1 200 OK (text/html)
9878	73.022294	172.16.0.1	192.168.10.50	HTTP	526	GET /dv/vulnerabilities/sqli/?id=1%27+and+1%3D1%23&Submit=Submit HTTP/1.1
9880	73.089657	192.168.10.50	172.16.0.1	HTTP	1906	HTTP/1.1 200 OK (text/html)
10352	81.854181	172.16.0.1	192.168.10.50	HTTP	603	GET /dv/vulnerabilities/sqli/?id=1%27+and+1%3D1+union+select+1%3D1 HTTP/1.1
10354	81.886725	192.168.10.50	172.16.0.1	HTTP	1947	HTTP/1.1 200 OK (text/html)
20371	93.294472	172.16.0.1	192.168.10.50	HTTP	666	GET /dv/vulnerabilities/sqli/?id=1%27+and+1%3D1+union+select+1%3D1 HTTP/1.1
20382	93.374995	192.168.10.50	172.16.0.1	HTTP	4215	HTTP/1.1 200 OK (text/html)
27576	127.125631	172.16.0.1	192.168.10.50	HTTP	665	GET /dv/vulnerabilities/sqli/?id=1%27+and+1%3D1+union+select+1%3D1 HTTP/1.1
27578	127.130020	192.168.10.50	172.16.0.1	HTTP	2087	HTTP/1.1 200 OK (text/html)
28590	140.822182	172.16.0.1	192.168.10.50	HTTP	589	GET /dv/vulnerabilities/sqli/?id=1%27&Submit=Submit HTTP/1.1
28592	140.824989	192.168.10.50	172.16.0.1	HTTP	596	HTTP/1.1 200 OK (text/html)
36181	154.175480	172.16.0.1	192.168.10.50	HTTP	602	GET /dv/vulnerabilities/sqli/?id=1%27+and+1%3D1%23&Submit=Submit HTTP/1.1

> Frame 9506: Packet, 513 bytes on wire (4104 bits), 513 bytes captured on interface 0	0000	00 19 b9 0a 69 f1 00 c1 b1 14 eb 31 08 00 45 00	...i..
> Ethernet II, Src: Cisco_14:eb:31 (00:c1:b1:14:eb:31), Dst: Dell_0a:60:82:01:00:00	0010	01 f3 e1 a6 40 00 3e 06 e2 72 ac 10 00 01 c0 a8	...@>
> Internet Protocol Version 4, Src: 172.16.0.1, Dst: 192.168.10.50	0020	0a 32 8d 64 00 50 16 93 84 4a bb 13 30 65 80 18	..2.d.P.
> Transmission Control Protocol, Src Port: 36196, Dst Port: 80, Seq: 1	0030	00 e5 60 a3 00 00 01 01 08 0a 01 3e 65 ed 03 e8	..`....
> Hypertext Transfer Protocol	0040	37 60 47 45 54 20 2f 64 76 2f 76 75 6c 6e 65 72	7"GET /
	0050	61 62 69 6c 69 74 69 65 73 2f 73 71 6c 69 2f 3f	abiliti

Pełna sesja HTTP: ramki 9506, 9508, 9878, 9880, 10352, 10354, 20371, 20382, 27576, 27578, 28590, 28592, 36181... — narastająca sekwencja SQL Injection

Frame 9506

GET /dv/vulnerabilities/sqli/?id=1%27&Submit=Submit — sonda apostrofem, ścieżka wskazuje na DVWA

Wszystkie odpowiedzi serwera

Kod HTTP/1.1 200 OK — brak blokowania, brak sygnałów filtracji (WAF)

Ocena

- **Hipoteza:** Aktywna eksploatacja podatności SQL Injection na aplikacji DVWA hostowanej na 192.168.10.50, przeprowadzona przez hosta 172.16.0.1 (po NAT — zgodnie z opisem scenariusza odpowiadający zewnętrznemu atakującemu 205.174.165.73). Konsekwentne odpowiedzi 200 OK sugerują brak ochrony aplikacyjnej i możliwe powodzenie ataku (odczyt danych z bazy).
- **Alternatywne wyjaśnienie:** Autoryzowany test penetracyjny / ćwiczenie na celowo podatnej aplikacji (DVWA jest narzędziem szkoleniowym) — do potwierdzenia przez właściciela środowiska/harmonogram testów.
- **Poziom pewności:** wysoki (wzorzec techniczny SQLi jednoznaczny) / średni–wysoki co do intencji, w zależności od kontekstu środowiska (lab vs produkcja).

Rekomendowane działania

- Korelacja z logami aplikacji/serwera WWW na 192.168.10.50 — sprawdzić treść odpowiedzi 200 OK pod kątem wycieku danych z bazy.
- Identyfikacja właściciela środowiska DVWA — potwierdzić, czy to zamierzone środowisko testowe, czy produkcyjna ekspozycja podatnej aplikacji.
- Jeśli nieautoryzowane: izolacja hosta 192.168.10.50 zgodnie z procedurą IR, wdrożenie WAF/parametryzacji zapytań, zablokowanie ruchu z 172.16.0.1 / 205.174.165.73 na firewallu.
- Korelacja czasowa ze scenario2 — sprawdzić, czy ten sam host (192.168.10.50) i/lub ta sama kampania łączy oba zdarzenia (SQLi 6 lipca → nadużycie FTP 7 lipca).